

JASMINE C. OMANDAM

My Journey into Authentication Vulnerabilities (Portswigger)

When I first began exploring PortSwigger's Web Security Academy, I thought authentication was straightforward just proving who you are before entering a system. But as I moved deeper into the modules, I realized authentication is the fragile gatekeeper of trust, and attackers are constantly testing its strength. What seemed simple at first unfolded into a complex web of vulnerabilities, logic flaws, and defense strategies.

The journey started with the basics: authentication versus authorization. Authentication is about identity proving that "**Carlos123**" really is Carlos. Authorization, however, is about permission what Carlos is allowed to do once inside. This distinction struck me as fundamental because attackers don't just want access; they want control. Understanding this difference set the stage for everything that followed.

Next, I learned how authentication vulnerabilities arise. They often stem from weak protections against brute-force attacks or flawed coding logic that lets attackers bypass authentication entirely. It was eye-opening to see how small oversights in development could lead to massive breaches. Authentication isn't just another feature it's the backbone of security, and when it breaks, everything else collapses.

The modules then revealed the impact of vulnerable authentication. If an attacker compromises a regular account, they gain access to personal data. If they compromise an administrator account, they can take over the entire system. This realization made me see authentication not just as a technical process but as the very foundation of trust between users and applications.

When I reached the section on password-based login vulnerabilities, I discovered how fragile the "something you know" factor really is. Passwords are only as strong as the protections around them. Attackers don't rely on random guessing they use brute-force attacks powered by wordlists, logic, and automation. If usernames follow predictable patterns like **firstname.lastname@company.com** or **admin**, attackers can easily generate lists of valid accounts. Once usernames are known, brute-forcing passwords becomes far more efficient. This taught me that security isn't just about complexity it's about unpredictability and layered defenses.

The labs on brute-forcing usernames and passwords were particularly revealing. They showed me how attackers think strategically, not chaotically. Username enumeration, flawed brute-force protection, and weak account-locking mechanisms all create openings. Each exercise felt like uncovering a new mindset, reshaping how I view login systems.

Finally, the modules emphasized defensive strategies. Rate limiting, account lockouts, multi-factor authentication, and careful verification logic are essential. I realized that authentication must be treated as a living system constantly tested, reinforced, and improved. Security isn't static; it's a continuous process of anticipating how attackers adapt.

Tools I Needed Along the Way

To make this journey practical, I relied on:

- Burp Suite for intercepting and manipulating login requests.
- SecLists wordlists to simulate brute-force attempts.
- Automation tools like Hydra or ffuf to understand large-scale brute-forcing.
- PortSwigger Labs as a safe environment to apply theory without risk.

What I Discovered

- Authentication is fragile if predictable.
- Attackers exploit patterns, not randomness.
- Brute-force is strategic, not chaotic.
- Defenses must be layered and resilient.

Walking through this learning path didn't just teach me about vulnerabilities it reshaped how I think about trust online. Authentication isn't a checkbox; it's the frontline of defense. And every flaw, no matter how small, is an open invitation to attackers.